FINGERPRINT //
9588D10EE5094DD9

// CONFIDENTIAL
STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Hong Kong Bank

NEXUS SCORE

80%

80

NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
INTEL	VALIDATED	Strategic
COVERT	VALIDATED	Strategic
COLLAB	VALIDATED	Strategic
CRISIS	GAP	Strategic

Resourcing & Schedule Summary

PART I.B: EXECUTION PROFILE

Executive Resourcing & Schedule Summary

The following summarizes the operational timeline and resourcing required to execute the defined Threat-Led Penetration Testing modules in alignment with regulatory mandates.

TOTAL ENGAGEMENT DAYS

65

ENGAGEMENT COMPLEXITY

HIGH

Automated TLPT Resourcing Allocation

ROLE	HEADCOUNT	PRIMARY RESPONSIBILITY
Threat Intel & Red Team Lead	1	Strategic oversight, regulatory coordination, and final QA.
Covert Red Team Operator	3	Technical execution, exploit dev, and assumed breach operations.

1.5 Regulatory Alignment: HKMA iCAST Hong Kong Framework

Narrative: Hong Kong Monetary Authority (HKMA) Cybersecurity Fortification Initiative (CFI) iCAST scoping.

REGULATORY BODY — **Hong Kong Monetary Authority (HKMA) iCAST (Hong Kong)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
CFI 2.0 – Pillar 1	Cybersecurity Assessment Framework (CAF)	Institutions must conduct a CAF self-assessment to determine their cybersecurity maturity level.	All critical systems and business functions serving retail and institutional clients.
CFI 2.0 – Pillar 2	Intelligence-led Cyber Attack Simulation (iCAST)	Perform controlled, covert, intelligence-led simulated attacks on live production systems.	Threat intelligence-derived simulation targeting CBS with systemic financial impact.
CFI 2.0 – Pillar 3	Cybersecurity Ecosystem Development	Contribution to the Hong Kong financial sector cybersecurity ecosystem and information sharing.	Participation in HKMA Cyber Intelligence Sharing Platform (CISP) post-engagement.

Mandatory Evidence Artifacts:

- CAF Self-Assessment Report
- Threat Intelligence Profile (TI-PHASE Output)
- iCAST Execution Log
- Closure Report & Control Effectiveness Summary
- Remediation Plan

IMPLEMENTATION GUIDANCE — **HKMA**

iCAST Execution

Simulations must cover the 'Assume Breach' methodology to assess the detection and response capabilities of the institution's Security Operations Center (SOC).

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Threat Scenarios & Modeling

PART I.C: THREAT INTELLIGENCE

Threat Intelligence Profiles

The following threat actors and attack scenarios have been selected to drive the execution methodology.

THREAT ACTOR	MOTIVATION	TARGET OBJECTIVE	PRIMARY TTPS
APT-FIN7 / Carbanak	Financial Crime â€“ Fraudulent SWIFT Transfers	Compromise SWIFT operator credentials and initiate fraudulent payments	Spearphishing, Credential Harvesting, LOTL, SWIFT API Abuse
APT-Lazarus Group	State-Sponsored â€“ Capital Generation	Lateral movement to core banking and treasury systems	Supply Chain Compromise, Watering Hole, Custom Malware Implants
Ransomware-as-a-Service (RaaS) Affiliate	Extortion â€“ Business Disruption	Encrypt critical file servers and BCPs to extort the institution	Initial Access Broker, Assumed Breach, Fast Encryption Payload

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Payload & Exploit Transmission	Zero-Knowledge End-to-End Encryption (E2EE)
Exfiltrated Data Storage	Ephemeral Air-Gapped Analysis Environment (256-bit AES)
Red Team Telemetry Retention	Secure SOC Aggregation (Strict 30-Day Limit)
Artifact Destruction	NIST 800-88 Compliant Cryptographic Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
HKMA	Assessment data and execution artifacts should be stored locally in Hong Kong in accordance with HKMA guidelines and the Personal Data (Privacy) Ordinance (PDPO).

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
HKMA	HKMA retains the right to directly review threat intelligence models, execution logs, and remediation plans. Institutions must notify HKMA of any critical vulnerabilities discovered during iCAST.

Operational Team Governance

White Team & Control Group Structure

In accordance with intelligence-led frameworks (CBEST/iCAST), the engagement must be overseen by a strictly segregated Control Group to ensure operational safety without alerting the defensive Blue Team.

GOVERNANCE BODY	REGULATORY RESPONSIBILITY	CLEARANCE LEVEL
The White Team	Engagement sponsors holding the emergency Kill-Switch. Responsible for defining the Critical Business Services (CBS) and Impact Tolerances.	Full Knowledge
The Control Group	A trusted subset of the client's internal IT/Security team who monitor the engagement for safety but do not participate in defense.	Full Knowledge
The Blue Team	The operational SOC and incident responders who must defend the network as if under a real attack.	Zero Knowledge
Threat Intel Provider	Independent vendor supplying the threat landscape profiles and attack scenarios to the Red Team.	Execution Phase
Covert Red Team	The execution unit simulating the Threat Actor's TTPs against the CBS.	Execution Phase

Rules of Engagement & Operational Safety

Rules of Engagement Baseline

The following operational safety constraints govern all technical execution activities.

CONTROL	AUTHORIZED CONSTRAINT
Testing window	09:00 - 17:00 GMT
Blackout dates	Q4 Freeze (Nov 15 - Jan 5)
Emergency stop contact	**Global CISO & White Team Lead (+1 555-0199)**
Authorized source IPs	198.51.100.0/24 (Red Team Infrastructure)

Emergency Kill Switch Protocol

- Stop immediately if a business service degrades, unexpected sensitive data is reached, or the client asks testing to pause.
- Document the last action, affected target, timestamp, evidence state, and restart condition before resuming.

Attack Primitives Matrix

The following operational boundaries define what the Red Team is legally authorized to execute against the financial infrastructure.

ATTACK VECTOR / PRIMITIVE	AUTHORIZATION STATUS	ACTION REQUIREMENTS
Spearphishing & Social Engineering	ALLOWED	Pre-approved lures; no harvesting of actual user passwords.
Assumed Breach / Internal Pivoting	ALLOWED	Standard stealth TTPs within defined targets.
Exploitation of Core Banking APIs	RESTRICTED	Requires explicit White Team go-ahead before live exploitation.
Physical Premise Tailgating	**PROHIBITED**	Physical intrusion is out of scope for this engagement.
Volumetric Denial of Service (DoS)	**PROHIBITED**	Network stress testing strictly forbidden.
Data Deletion / Ransomware Simulation	**PROHIBITED**	Simulated safe payloads only; no actual data destruction.

Critical Business Services & Impact Tolerance

PART II.C: CBS IMPACT TOLERANCE

STRICTLY CONFIDENTIAL // STRATEGIC SCOPE

Critical Business Services (CBS) Scope

In accordance with DORA and CBEST, the engagement scope is defined by Critical or Important Functions (CIFs) and their maximum impact tolerances.

CBS ID	BUSINESS SERVICE	UNDERLYING TECHNOLOGY STACK	MAX TOLERABLE DOWNTIME	DATA CLASSIFICATION
CBS-001	SWIFT Payment Gateway Processing	Hybrid Cloud / On-Premise Mainframe	RTO < 4 Hours	Tier 1 - Systemic Critical
CBS-002	Core Retail Banking API Services	AWS Kubernetes Cluster (eu-west-1)	RTO < 1 Hour	Tier 1 - High Priority
CBS-003	Institutional FX Trading Platform	Co-location Data Centre / On-Premise	RTO < 30 Minutes	Tier 1 - Systemic Critical

Access & Test Data Readiness

Standard testing prerequisites apply: Client must provide stable network access (VPN/Jump host), valid application credentials (min. 2 per role), and any required API documentation prior to the start of the testing window.

Third-Party ICT Supply Chain Scope

PART II.D: THIRD-PARTY RISK

Third-Party ICT Dependency Register

No third-party ICT dependencies or hosted environments have been declared in scope. Testing is restricted to first-party infrastructure.

Technical Scope of Work

TI-PHASE — **Targeted Threat Intelligence Gathering**

Formally scoped intelligence gathering phase designed to identify threat actors, define attack scenarios, and produce the Threat Intelligence Profile required before Red Team execution.

Allocated Schedule: 15 Days

RT-COVERT — **Covert Red Team Execution**

Intelligence-led, objective-based penetration testing executing the scenarios defined in the TI-PHASE. Includes stealth, evasion, and assumed-breach scenarios against core financial systems.

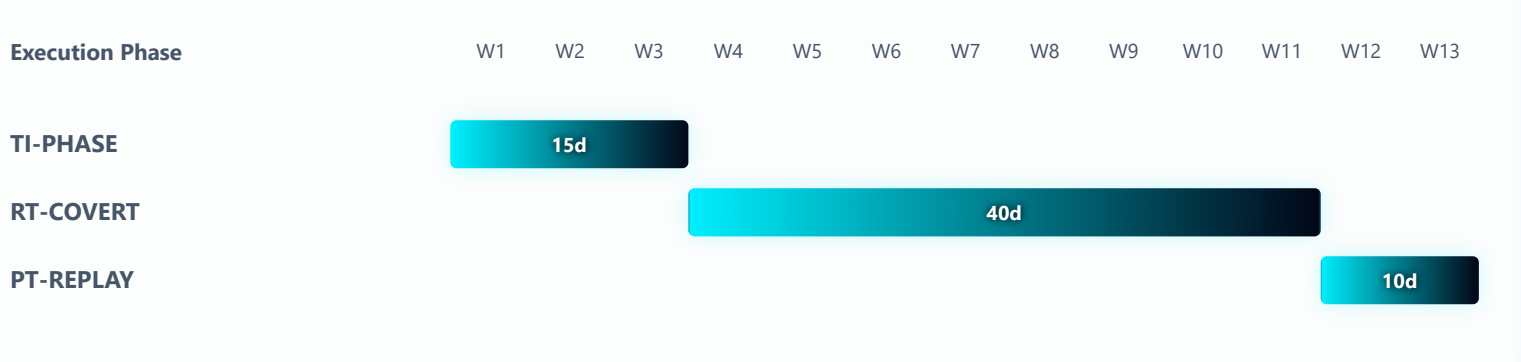
Allocated Schedule: 40 Days

PT-REPLAY — **Purple Team Replay Exercises**

Collaborative replay of Red Team attack chains alongside the defensive Blue Team to validate SOC detections, incident response capabilities, and SIEM rule effectiveness.

Allocated Schedule: 10 Days

Execution Timeline (Gantt)



3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	CONTROL NAME	FRAMEWORK	REFERENCE	IMPACT
CB_01	Core Banking Network Segmentation	DORA	Art. 24 (TLPT)	Critical
CB_02	Retail Payment Infrastructure Isolation	DORA	Art. 26 (ICT Resilience)	Critical
SW_01	SWIFT Gateway Network Isolation	PRA CBEST	Objective A – Segregation	Critical
SW_02	SWIFT Messaging Integrity Validation	PRA CBEST	Objective B – Data Integrity	Critical
IAM_01	Privileged Access Management (PAM)	FRB	SR 13-1 – Access Control	High
IAM_02	Service Account Credential Hygiene	MAS TRM	Section 12.3 – IAM	High
IAM_03	Multi-Factor Authentication Enforcement	MAS TRM	Section 12.4 – Authentication	High
TI_01	Threat Intelligence Profile Development	HKMA iCAST	CFI 2.0 – TI Framework	High
TI_02	Threat Actor Attribution & Profiling	PRA CBEST	CBEST TI Module	High
TI_03	Attack Scenario Development (MITRE ATT&CK)	HKMA iCAST	CFI 2.0 – Scenario Modelling	High
TI_04	Threat-Led Defense Posture Assessment	HKMA iCAST	CFI-2 – Posture Review	High
IR_03	SOC Detection & SIEM Validation	MAS TRM	Section 13 – Incident Response	High
IR_04	Purple Team Replay & Remediation Verification	FRB	SR 11-7 – Model Validation	Medium
DR_02	RTO / RPO Objective Testing Under Load	FRB	SR 13-1 – Continuity	High
API_01	Open Banking API Security Boundary	MAS TRM	Section 12.1 – API Controls	High
CLD_01	Cloud Workload Lateral Movement Detection	DORA	Art. 30 – ICT Third-Party Risk	High

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	THREAT INTEL PROVIDER	COVERT RED TEAM LEAD	CLIENT WHITE TEAM	CLIENT CONTROL GROUP	CLIENT SECURITY OPS (SOC)	CLIENT EXEC SPONSOR / CISO
Targeted Threat Intelligence Gathering	R	C	A	I	I	I
Attack Scenario & TTP Development	R	C	A	I	I	I
Critical Business Service (CBS) Declaration	I	I	A	C	C	R
Regulator & Scope Notification	I	C	A	I	I	R
White Team Briefing & Kill-Switch Assignment	I	C	R	C	I	A
Covert Red Team Execution (TLPT)	C	R	A	I	I	I
Emergency Kill-Switch Activation	I	C	R	C	I	A
Purple Team Replay Exercises	C	R	I	I	A	I
SOC Detection Rate Validation	I	C	A	C	R	I
Executive Crisis Management Tabletop	I	C	A	I	I	R
Remediation Planning & Sign-off	I	C	C	I	R	A
Regulator Artifact Submission	C	C	I	I	R	A

Regulatory Deliverables Schedule

Regulatory Deliverables Schedule

The following reports and evidence logs are contractually required to satisfy the loaded regulatory frameworks.

REGULATORY BODY	MANDATORY DELIVERABLE ARTIFACT
Hong Kong Monetary Authority (HKMA) iCAST	CAF Self-Assessment Report
Hong Kong Monetary Authority (HKMA) iCAST	Threat Intelligence Profile (TI-PHASE Output)
Hong Kong Monetary Authority (HKMA) iCAST	iCAST Execution Log
Hong Kong Monetary Authority (HKMA) iCAST	Closure Report & Control Effectiveness Summary
Hong Kong Monetary Authority (HKMA) iCAST	Remediation Plan

Quality Assurance & Peer Review

PART IV.B: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: TLPT Qualified Red Team Reviewer

Mandatory Threat-Led Penetration Testing (TLPT) review gate. Evidence and kill-chain paths must be validated by a certified Red Team peer reviewer before report release.

Verification & Sign-off

PART V: AUTHORIZATION

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // 9588D10EE5094DD9F84DE5478B76C72E744DE431A0A71E2C1D74705513052CE6

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor: _____

Date: _____